

Write UP Varnier Alexis - Ciszak Lisa - Hault Théo - Picamal Julien (A1)

Explications

Tunnel GRE + IPSec

L'opérateur doit mettre en place un tunnel authentifié et chiffré dès lors qu'une communication liée au SIE transite par un réseau non maîtrisé.

Il est recommandé de mettre en œuvre un tunnel reposant sur la technologie de VPN IPsec, configuré conformément aux recommandations de sécurité relatives à IPsec pour la protection des flux réseau de l'ANSSI. À défaut, la technologie TLS peut être employée.

L'opérateur doit configurer le poste de travail nomade afin qu'il établisse toujours un tunnel authentifié et chiffré depuis le poste de travail jusqu'au SIE, ou à défaut, jusqu'au SI interne de l'opérateur.

Le tunnel doit couvrir l'ensemble des communications. Ainsi, l'utilisateur ne doit pas pouvoir désactiver temporairement le tunnel (pour se connecter au portail captif d'un hôtel par exemple), ni pouvoir accéder directement à Internet ou communiquer avec un équipement sur le réseau local (imprimante personnelle à domicile).

Source : ANSI Accès à distance (règle 9)

IPSec

L'IPSec est un protocole réseau qui permet de fournir plusieurs services de sécurité pour les paquets IP tels que le cryptage des données, l'authentification, l'intégrité et la confidentialité. Cela a pour objectif de fournir une communication cryptée sécurisée entre deux nœuds dans un réseau. Il est souvent utilisé dans les réseaux privés virtuels (VPN).

SA : Security Association

Une SA (ISAKMP SA ou IKE SA) est une politique unidirectionnelle (dans un seul sens) qui définit la manière de chiffrement des flux (Algorithmes et Clés de Cryptage). Donc, chaque tunnel fonctionnant avec IPsec aura 2 SAs, une pour chaque direction.

Il y a plusieurs étapes dans la Politique de SA :

- Choisir l'algorithme de chiffrement à utiliser (Ex : 3DES)
- Choisir l'algorithme de Cryptage/Intégrité (Ex : MD5)
- Choisir le mode d'authentification des sessions (Ex : Certificat de clé publique)
- Utilisation de Protocole AH (Authentication Header) ou ESP (Encapsulated Security Payload) avec leurs paramètres correspondants.

Phases 1 et 2

Il existe deux phases de négociation pour un tunnel IPsec : Phase 1 et Phase 2.

Au cours de la **Phase 1**, les deux extrémités d'un tunnel établissent un canal sécurisé et procèdent à la négociation des paramètres SA (Authentication, Intégrité, ...) et échangent les clés / certificats (IKE).

Une fois la phase 1 terminée, les deux extrémités pourront échanger les données (Data) en toute sécurité, elles doivent donc décider quel trafic traversera le tunnel avec quel cryptage à appliquer. C'est la **Phase 2**.

Au cours de la **Phase 2**, les deux extrémités du tunnel négocient la manière de chiffrement et d'envoi des données en fonction des politiques de sécurité implémentées. Si les politiques des deux côtés sont d'accord, le tunnel sera opérationnel et prêt à être utilisé. Les données sont envoyées à travers le canal sécurisé établi lors de la Phase 1.

AH (Authentication Header) vs ESP (Encapsulating Security Payload)

AH et **ESP** sont deux protocoles différents utilisés dans la suite IPSec.

- **AH (Authentication Header)** : Ce protocole assure l'intégrité ainsi que l'authentification des origines de données.
L'en-tête AH permet de signer numériquement l'intégralité du contenu de chaque paquet envoyé par l'expéditeur. Les algorithmes de chiffrement et de hachage souvent utilisés sont DES, MD5, SHA-1... Cela permet de bien lutter contre la fraude et la modification de données. Cependant, AH ne permet pas de chiffrer les données, elles restent visibles.
- **ESP (Encapsulating Security Payload)** : Ce protocole assure la confidentialité, l'intégrité des données, l'authentification de l'origine des données ainsi qu'un service anti-relecture.
L'ESP chiffre l'intégralité des données de la couche applicative supérieure en ajoutant trois composants différents : un en-tête ESP, une bande-annonce ESP et un bloc d'authentification ESP.

Différences clés entre AH et ESP

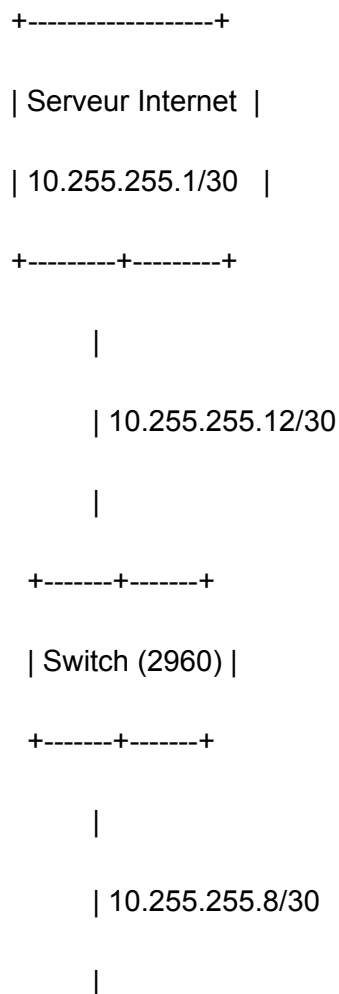
- **AH** assure l'intégrité et l'authentification des données, mais ne chiffre pas les données, donc elles sont visibles.
- **ESP** chiffre les données pour en assurer la confidentialité, tout en maintenant l'intégrité et l'authentification des données.

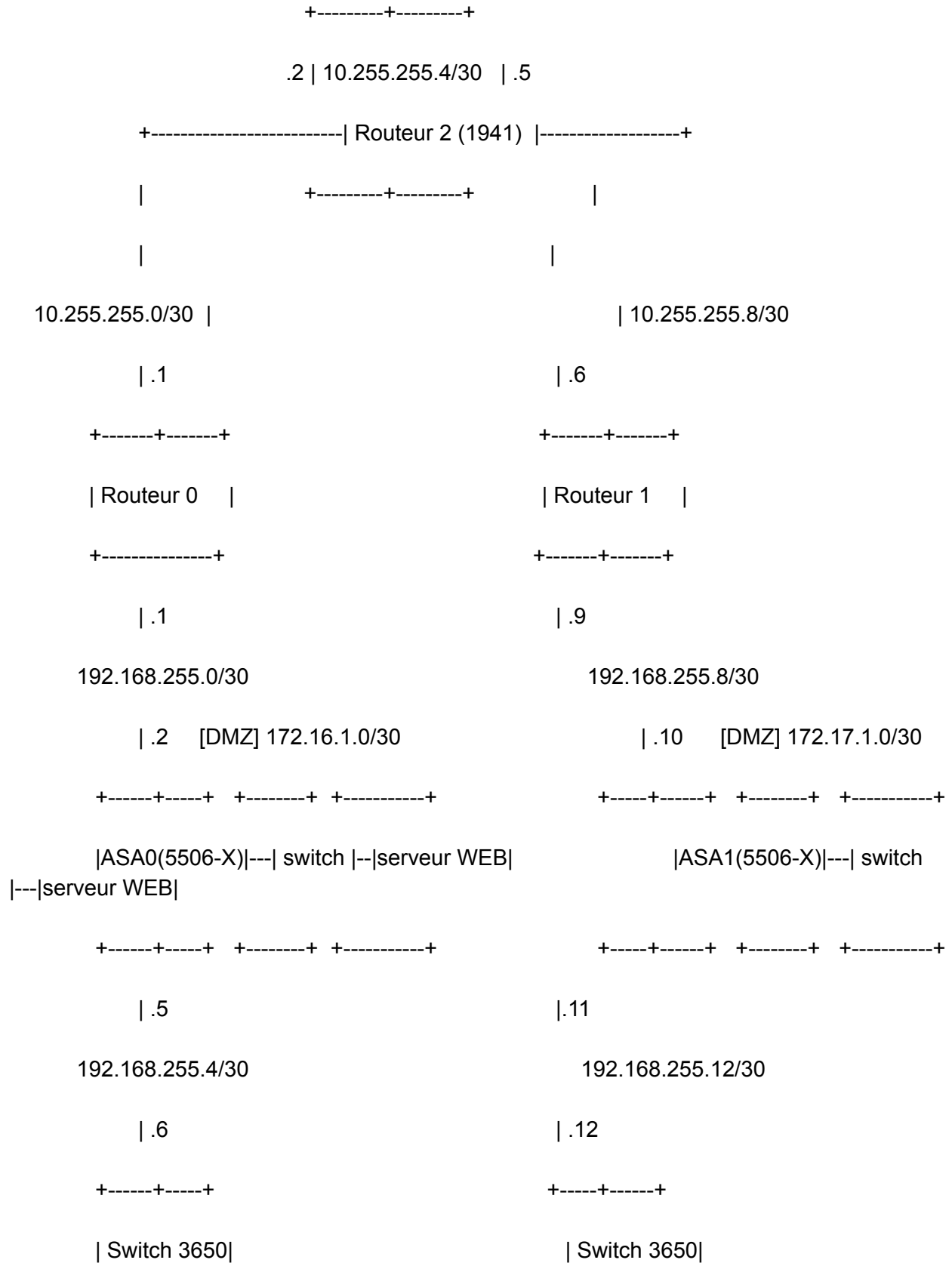
Protocoles :

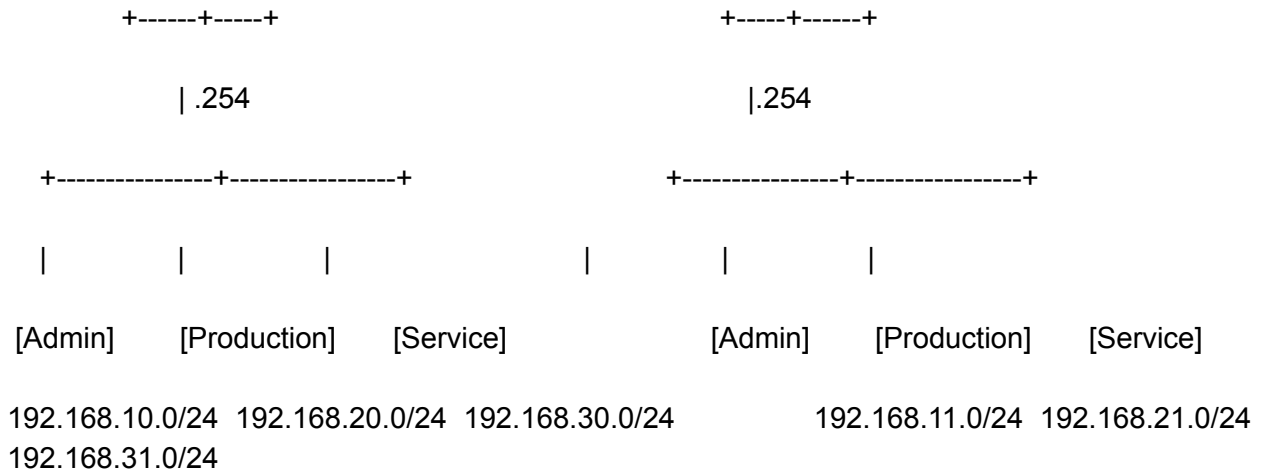
- L'ID du protocole IP pour AH est **51**.
- L'ID du protocole IP pour ESP est **50**.

Configuration de l'architecture réseau

Schema du reseau







R0

```
license boot module c1900 technology-package securityk9
```

```
crypto isakmp policy 10
```

```
encr aes
```

```
authentication pre-share
```

```
group 5
```

```
crypto isakmp key MY_SECRET_KEY address 10.255.255.6
```

```
crypto ipsec transform-set MY_TRANSFORM_SET esp-aes esp-sha-hmac
```

```
crypto map MY_CRYPTOMAP 10 ipsec-isakmp
```

```
set peer 10.255.255.6
```

```
set transform-set MY_TRANSFORM_SET
```

```
match address 101
```

```
interface Tunnel0
```

```
ip address 10.200.255.1 255.255.255.252
```

```
mtu 1476
```

tunnel source GigabitEthernet0/0

tunnel destination 10.255.255.6

interface GigabitEthernet0/0

ip address 10.255.255.1 255.255.255.252

ip ospf 1 area 0

ip nat outside

duplex auto

speed auto

crypto map MY_CRYPTOMAP

interface GigabitEthernet0/1

ip address 192.168.255.1 255.255.255.252

ip ospf 2 area 0

ip nat inside

duplex auto

speed auto

router ospf 1

log-adjacency-changes

network 10.255.255.0 0.0.0.3 area 0

router ospf 2

log-adjacency-changes

network 192.168.255.0 0.0.0.3 area 0

ip nat inside source list NAT interface GigabitEthernet0/0 overload

```
ip route 172.17.1.0 255.255.255.0 10.200.255.2

ip route 192.168.255.8 255.255.255.252 10.200.255.2

ip route 192.168.255.12 255.255.255.252 10.200.255.2

ip route 192.168.11.0 255.255.255.0 10.200.255.2

ip route 192.168.21.0 255.255.255.0 10.200.255.2

ip route 192.168.31.0 255.255.255.0 10.200.255.2

access-list 101 permit gre host 10.255.255.1 host 10.255.255.6

ip access-list extended NAT

deny ip 192.168.0.0 0.0.255.255 192.168.0.0 0.0.255.255

permit ip 192.168.0.0 0.0.255.255 any
```

R1

```
license boot module c1900 technology-package securityk9

crypto isakmp policy 10

encr aes

authentication pre-share

group 5

!

crypto isakmp key MY_SECRET_KEY address 10.255.255.1

crypto ipsec transform-set MY_TRANSFORM_SET esp-aes esp-sha-hmac

!

crypto map MY_CRYPTOMAP 10 ipsec-isakmp
```

```
set peer 10.255.255.1

set transform-set MY_TRANSFORM_SET

match address 101

interface Tunnel0

ip address 10.200.255.2 255.255.255.252

mtu 1476

tunnel source GigabitEthernet0/0

tunnel destination 10.255.255.1

!

!

interface GigabitEthernet0/0

ip address 10.255.255.6 255.255.255.252

ip ospf 1 area 0

ip nat outside

duplex auto

speed auto

crypto map MY_CRYPTOMAP

!

interface GigabitEthernet0/1

ip address 192.168.255.9 255.255.255.252

ip ospf 2 area 0

ip nat inside
```

duplex auto

speed auto

!

interface Vlan1

no ip address

shutdown

!

router ospf 1

log-adjacency-changes

network 10.255.255.4 0.0.0.3 area 0

!

router ospf 2

log-adjacency-changes

network 192.168.255.8 0.0.0.3 area 0

!

ip nat inside source list NAT interface GigabitEthernet0/0 overload

ip classless

ip route 192.168.255.0 255.255.255.252 10.200.255.1

ip route 192.168.255.4 255.255.255.252 10.200.255.1

ip route 192.168.10.0 255.255.255.0 10.200.255.1

ip route 192.168.20.0 255.255.255.0 10.200.255.1

```
ip route 192.168.30.0 255.255.255.0 10.200.255.1
```

```
ip route 172.16.1.0 255.255.255.0 10.200.255.1
```

```
!
```

```
ip flow-export version 9
```

```
!
```

```
!
```

```
access-list 101 permit gre host 10.255.255.6 host 10.255.255.1
```

```
ip access-list extended NAT
```

```
deny ip 192.168.0.0 0.0.255.255 192.168.0.0 0.0.255.255
```

```
permit ip 192.168.0.0 0.0.255.255 any
```

```
R2
```

```
interface Loopback0
```

```
ip address 2.2.2.2 255.255.255.255
```

```
!
```

```
interface GigabitEthernet0/0
```

```
ip address 10.255.255.9 255.255.255.252
```

```
duplex auto
```

```
speed auto
```

```
!
```

```
interface GigabitEthernet1/0
```

```
ip address 10.255.255.2 255.255.255.252
```

```
duplex auto
```

speed auto

!

interface GigabitEthernet2/0

ip address 10.255.255.5 255.255.255.252

duplex auto

speed auto

!

router ospf 1

log-adjacency-changes

network 10.255.255.0 0.0.0.3 area 0

network 10.255.255.4 0.0.0.3 area 0

network 10.255.255.8 0.0.0.3 area 0

ASA0

interface GigabitEthernet1/1

nameif outside

security-level 0

ip address 192.168.255.2 255.255.255.252

interface GigabitEthernet1/2

nameif DMZ

security-level 50

ip address 172.16.1.254 255.255.255.0

interface GigabitEthernet1/3

nameif inside

security-level 100

ip address 192.168.255.5 255.255.255.252

route outside 0.0.0.0 0.0.0.0 192.168.255.1 1

!

access-list OUTSIDE-IN extended permit icmp any any echo-reply

access-list OUTSIDE-IN extended permit tcp any 172.16.1.0 255.255.255.0 eq www

access-list OUTSIDE-IN extended permit tcp any 172.16.1.0 255.255.255.0 eq 443

access-list OUTSIDE-IN extended permit tcp host 172.17.1.10 any

access-list OUTSIDE-IN extended permit tcp host 10.255.255.14 any

access-list OUTSIDE-IN extended permit icmp 192.168.0.0 255.255.0.0 any

access-list DMZ-OUTSIDE extended permit tcp 172.16.1.0 255.255.255.0 any eq www

access-list DMZ-OUTSIDE extended permit tcp 172.16.1.0 255.255.255.0 any eq 443

access-list DMZ-OUTSIDE extended deny ip any any

access-list DMZ-INSIDE extended permit tcp host 172.16.1.10 192.168.10.0 255.255.255.0

access-group OUTSIDE-IN in interface outside

access-group DMZ-OUTSIDE out interface outside

access-group DMZ-INSIDE out interface inside

class-map inspection_default

match default-inspection-traffic

policy-map type inspect dns preset_dns_map

parameters

message-length maximum 512

policy-map global_policy

class inspection_default

inspect dns preset_dns_map

inspect ftp

inspect tftp

service-policy global_policy global

router ospf 1

log-adjacency-changes

network 172.16.1.0 255.255.255.0 area 0

network 192.168.255.0 255.255.255.252 area 0

network 192.168.255.4 255.255.255.252 area 0

ASA1

interface GigabitEthernet1/1

nameif outside

security-level 0

ip address 192.168.255.10 255.255.255.252

interface GigabitEthernet1/2

nameif DMZ

security-level 0

ip address 172.17.1.254 255.255.255.0

interface GigabitEthernet1/3

nameif inside

security-level 100

ip address 192.168.255.13 255.255.255.252

route outside 0.0.0.0 0.0.0.0 192.168.255.9 1

access-list OUTSIDE-IN extended permit icmp any any echo-reply

access-list OUTSIDE-IN extended permit tcp any 172.17.1.0 255.255.255.0 eq www

access-list OUTSIDE-IN extended permit tcp any 172.17.1.0 255.255.255.0 eq 443

access-list OUTSIDE-IN extended permit tcp host 172.16.1.10 any

access-list OUTSIDE-IN extended permit tcp host 10.255.255.14 any

access-list OUTSIDE-IN extended permit icmp 192.168.0.0 255.255.0.0 any

access-list DMZ-OUTSIDE extended permit tcp 172.17.1.0 255.255.255.0 any eq www

access-list DMZ-OUTSIDE extended permit tcp 172.17.1.0 255.255.255.0 any eq 443

access-list DMZ-OUTSIDE extended deny ip any any

access-list DMZ-INSIDE extended permit tcp host 172.17.1.10 192.168.11.0 255.255.255.0

access-group OUTSIDE-IN in interface outside

access-group DMZ-OUTSIDE out interface outside

access-group DMZ-INSIDE out interface inside

class-map inspection_default

match default-inspection-traffic

policy-map type inspect dns preset_dns_map

parameters

message-length maximum 512

policy-map global_policy

class inspection_default

inspect dns preset_dns_map

inspect ftp

inspect tftp

service-policy global_policy global

router ospf 1

log-adjacency-changes

network 172.17.1.0 255.255.255.0 area 0

network 192.168.255.8 255.255.255.252 area 0

network 192.168.255.12 255.255.255.252 area 0

L3 (1)

interface GigabitEthernet1/0/1

no switchport

ip address 192.168.10.254 255.255.255.0

duplex auto

speed auto

interface GigabitEthernet1/0/2

no switchport

ip address 192.168.20.254 255.255.255.0

ip access-group 120 in

duplex auto

speed auto

interface GigabitEthernet1/0/3

no switchport

ip address 192.168.30.254 255.255.255.0

ip access-group 130 in

duplex auto

speed auto

interface GigabitEthernet1/0/24

no switchport

ip address 192.168.255.6 255.255.255.252

duplex auto

speed auto

router ospf 1

log-adjacency-changes

network 192.168.10.0 0.0.0.255 area 0

network 192.168.20.0 0.0.0.255 area 0

network 192.168.30.0 0.0.0.255 area 0

network 192.168.255.4 0.0.0.3 area 0

ip classless

```
ip route 0.0.0.0 0.0.0.0 192.168.255.1
```

```
access-list 120 permit ip 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255
```

```
access-list 120 permit ip 192.168.20.0 0.0.0.255 192.168.11.0 0.0.0.255
```

```
access-list 120 deny ip any any
```

```
access-list 130 permit ip 192.168.30.0 0.0.0.255 192.168.11.0 0.0.0.255
```

```
access-list 130 permit ip 192.168.30.0 0.0.0.255 192.168.10.0 0.0.0.255
```

```
access-list 130 deny ip any any
```

L3 (2)

```
interface GigabitEthernet1/0/1
```

```
no switchport
```

```
ip address 192.168.11.254 255.255.255.0
```

```
duplex auto
```

```
speed auto
```

```
!
```

```
interface GigabitEthernet1/0/2
```

```
no switchport
```

```
ip address 192.168.21.254 255.255.255.0
```

```
ip access-group 120 in
```

```
duplex auto
```

```
speed auto
```

```
!
```

```
interface GigabitEthernet1/0/3
```

```
no switchport
```

```
ip address 192.168.31.254 255.255.255.0
```

```
ip access-group 130 in
```

```
duplex auto
```

```
speed auto
```

```
interface GigabitEthernet1/0/24
```

```
no switchport
```

```
ip address 192.168.255.14 255.255.255.252
```

```
duplex auto
```

```
speed auto
```

```
interface Vlan1
```

```
no ip address
```

```
shutdown
```

```
!
```

```
router ospf 1
```

```
log-adjacency-changes
```

```
network 192.168.11.0 0.0.0.255 area 0
```

```
network 192.168.21.0 0.0.0.255 area 0
```

```
network 192.168.31.0 0.0.0.255 area 0
```

```
network 192.168.255.12 0.0.0.3 area 0
```

```
!
```

ip classless

ip route 0.0.0.0 0.0.0.0 192.168.255.13

!

ip flow-export version 9

!

!

access-list 120 permit ip 192.168.21.0 0.0.0.255 192.168.10.0 0.0.0.255

access-list 120 permit ip 192.168.21.0 0.0.0.255 192.168.11.0 0.0.0.255

access-list 120 deny ip any any

access-list 130 permit ip 192.168.31.0 0.0.0.255 192.168.10.0 0.0.0.255

access-list 130 permit ip 192.168.31.0 0.0.0.255 192.168.11.0 0.0.0.255

access-list 130 deny ip any any

switch VLAN 800

!

interface FastEthernet0/1

switchport access vlan 800

interface GigabitEthernet0/1

switchport access vlan 1

interface GigabitEthernet0/2

switchport mode trunk

```
router VLAN 800
```

```
interface GigabitEthernet0/0.1
```

```
encapsulation dot1Q 1 native
```

```
ip address 10.255.255.10 255.255.255.252
```

```
!
```

```
interface GigabitEthernet0/0.800
```

```
encapsulation dot1Q 800
```

```
ip address 10.255.255.13 255.255.255.252
```

```
!
```

```
interface GigabitEthernet0/1
```

```
no ip address
```

```
duplex auto
```

```
speed auto
```

```
shutdown
```

```
!
```

```
interface Vlan1
```

```
no ip address
```

```
shutdown
```

```
!
```

```
router ospf 1
```

```
log-adjacency-changes
```

```
network 10.255.255.8 0.0.0.3 area 0
```

```
network 10.255.255.12 0.0.0.3 area 0
```

Mise en place d'un serveur DNS avec DNSSEC (Varnier Alexis)

Installation et configuration du serveur DNS

Installation de Bind9

```
sudo apt-get update
```

```
sudo apt-get install bind9
```

```
systemctl status bind9
```

Configuration de la zone

Éditer `/etc/bind/named.conf.local` :

```
zone "societe3.pepiniere" {  
  
    type master;  
  
    file "/etc/bind/db.societe3.pepiniere";  
  
};
```

Créer `/etc/bind/db.societe3.pepiniere` :

```
$TTL 86400
```

```
@ IN SOA ns1.societe3.pepiniere. admin.societe3.pepiniere. (
```

```
    2025020601 ; Serial
```

```
    3600      ; Refresh
```

```
    1800      ; Retry
```

604800 ; Expire

86400 ; Negative Cache TTL

)

IN NS ns1.societe3.pepiniere.

ns1 IN A 192.31.25.13

www IN A 192.31.25.20

Redémarrer Bind9 :

```
sudo systemctl restart bind9
```

Test de résolution sur le client

```
dig www.societe3.pepiniere @192.31.25.13
```

Mise en place de DNSSEC

Génération des clés

```
cd /etc/bind
```

```
sudo dnssec-keygen -a RSASHA256 -b 2048 -n ZONE societe3.pepiniere
```

```
sudo dnssec-keygen -f KSK -a RSASHA256 -b 4096 -n ZONE societe3.pepiniere
```

Inclure les clés dans `/etc/bind/db.societe3.pepiniere` :

```
$INCLUDE "/etc/bind/Ksociete3.pepiniere.+008+XXXX.key"
```

```
$INCLUDE "/etc/bind/Ksociete3.pepiniere.+008+YYYY.key"
```

Signer la zone :

```
sudo dnssec-signzone -o societe3.pepiniere /etc/bind/db.societe3.pepiniere
```

Modifier `/etc/bind/named.conf.local` :

```
zone "societe3.pepiniere" {
```

```
type master;  
  
file "/etc/bind/db.societe3.pepiniere.signed";  
  
};
```

Redémarrer Bind9 :

```
sudo systemctl restart bind9
```

Vérification de la signature DNSSEC

Commande : dig +dnssec www.societe3.pepiniere

```
:: <<>> DiG 9.18.1-1ubuntu1.3-Ubuntu <<>> +dnssec www.societe3.pepiniere
```

```
:: global options: +cmd
```

```
:: Got answer:
```

```
:: ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 40171
```

```
:: flags: qr aa rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1
```

```
:: OPT PSEUDOSECTION:
```

```
; EDNS: version: 0, flags: do; udp: 1232
```

```
; COOKIE: 5fae5c3eb3ec343a0100000067d82c29739dba841e9ec678 (good)
```

```
:: QUESTION SECTION:
```

```
;www.societe3.pepiniere.    IN      A
```

```
:: ANSWER SECTION:
```

```
www.societe3.pepiniere.    86400 IN      A      192.31.25.20
```

www.societe3.pepiniere. 86400 IN RRSIG 8 3 86400 20250411063104
20250312063104 47391 societe3.pepiniere.
EPCDRtmJ9EXoMU6g3Uljc3vJqOBDt4LgC0mpCN8ctEUZcwGxjBJOPjL4
xEckbeWfZ9D9Lmf9fOPI1U34FVLudFPpIRnOHjuZfH7RYrkV5wUW2Li5
Syd7C3GiVvRKd3EbwcXgzoE+8bSfQ3tY+Nn2eRdtRE/PQC7WUxiu0vtA
xB3xgWQdT2LfmSebV4VC711ZtwljKc9K6ZvQXfYhhXk0ZFv47Vz7EIlm
cKzAxldcOKcEecp8piLM4xiLmxXBudtETpYnbD3EKrvImOgmE7LdO79s
/UrsAJa2Bn+HzmLth6EN47j9X41cRGU+oHIK2MiFNstd2JHuPcU5Uz8b 9Wf8sw==

;; Query time: 0 msec

;; SERVER: 192.31.25.13#53(192.31.25.13) (UDP)

;; WHEN: Mon Mar 17 15:05:30 CET 2025

;; MSG SIZE rcvd: 401

Commande : dig +multiline @192.31.25.13 societe3.pepiniere DNSKEY

;; <<>> DiG 9.18.1-1ubuntu1.3-Ubuntu <<>> +multiline @192.31.25.13 societe3.pepiniere
DNSKEY

; (1 server found)

;; global options: +cmd

;; Got answer:

;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 64932

;; flags: qr aa rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:

; EDNS: version: 0, flags:; udp: 1232

; COOKIE: b511159830f5df1c0100000067d82c4b846aee5cb4a3ba59 (good)

:: QUESTION SECTION:

;societe3.pepiniere. IN DNSKEY

:: ANSWER SECTION:

(contient les clés DNSKEY détaillées)

Validation DNSSEC côté client (optionnel)

```
sudo nano /etc/systemd/resolved.conf
```

```
sudo systemctl restart systemd-resolved
```

```
resolvectl status
```

Ajout des forwarders de l'IUT pour un accès Internet

Éditer `/etc/bind/named.conf.options` :

```
options {  
  
    directory "/var/cache/bind";  
  
    dnssec-validation auto;  
  
    forwarders {  
  
        172.18.26.101;  
  
        172.18.25.102;  
  
    };  
  
    allow-recursion { any; };  
  
    allow-query { any; };
```

```
};
```

Redémarrer Bind9 :

```
sudo systemctl restart bind9
```

Sécurisation Web avec PostgreSQL et Apache (Ciszak Lisa)

Installer Apache et PHP

On commence par installer Apache, PHP et les extensions nécessaires:

```
sudo apt update
```

```
sudo apt install apache2 php php-cli php-mbstring php-xml php-bcmath unzip curl -y
```

Installer PostgreSQL

On installe PostgreSQL et l'extension PHP pour PostgreSQL:

```
sudo apt install postgresql postgresql-contrib php-pgsql -y
```

On vérifie que le service PostgreSQL est bien actif:

```
sudo systemctl status postgresql
```

Si le service n'est pas actif:

```
sudo systemctl start postgresql
```

```
sudo systemctl enable postgresql
```

Configuration de PostgreSQL

On se connecte à PostgreSQL en tant qu'utilisateur postgres:

```
sudo -i -u postgres
```

psql

Créer la base de données et un utilisateur:

```
CREATE DATABASE protection_donnees;
```

```
CREATE USER admin WITH ENCRYPTED PASSWORD 'progtr00';
```

```
GRANT ALL PRIVILEGES ON DATABASE protection_donnees TO admin;
```

\q

On crée la table users:

```
sudo -u postgres psql
```

```
\c protection_donnees
```

```
CREATE TABLE users (
```

```
    id SERIAL PRIMARY KEY,
```

```
    username VARCHAR(50) UNIQUE NOT NULL,
```

```
    password TEXT NOT NULL
```

```
);
```

```
\d users
```

On crée un user et on accorde des privilèges à l'utilisateur webuser et on limite les permissions:

```
CREATE USER webuser WITH ENCRYPTED PASSWORD 'progtr00';
```

```
GRANT CONNECT ON DATABASE protection_donnees TO webuser;
```

```
GRANT ALL PRIVILEGES ON TABLE users TO webuser;
```

```
GRANT USAGE, SELECT, UPDATE ON SEQUENCE users_id_seq TO webuser;
```

```
REVOKE ALL ON users FROM webuser;
```

```
GRANT SELECT, INSERT, UPDATE, DELETE ON users TO webuser;
```

On redémarre le service:

```
sudo systemctl restart postgresql
```

On peut se connecter à la base de données pour vérifier:

```
sudo -u postgres psql
```

```
\c protection_donnees
```

```
SELECT * FROM users;
```

On empêche les connexions distantes dans **/etc/postgresql/14/main/postgresql.conf**

```
listen_addresses = 'localhost'
```

/etc/postgresql/14/main/pg_hba.conf

```
# PostgreSQL Client Authentication Configuration File
```

```
# =====
```

```
#
```

```
# Refer to the "Client Authentication" section in the PostgreSQL
```

```
# documentation for a complete description of this file. A short
```

```
# synopsis follows.
```

```
#
```

```
# This file controls: which hosts are allowed to connect, how clients
```

```
# are authenticated, which PostgreSQL user names they can use, which
```

```
# databases they can access. Records take one of these forms:
```

```
#
```

```
# local          DATABASE USER METHOD [OPTIONS]
```

```
# host      DATABASE USER ADDRESS METHOD [OPTIONS]

# hostssl   DATABASE USER ADDRESS METHOD [OPTIONS]

# hostnssl  DATABASE USER ADDRESS METHOD [OPTIONS]

# hostgssenc DATABASE USER ADDRESS METHOD [OPTIONS]

# hostnogssenc DATABASE USER ADDRESS METHOD [OPTIONS]

#

# (The uppercase items must be replaced by actual values.)

#

# The first field is the connection type:

# - "local" is a Unix-domain socket

# - "host" is a TCP/IP socket (encrypted or not)

# - "hostssl" is a TCP/IP socket that is SSL-encrypted

# - "hostnssl" is a TCP/IP socket that is not SSL-encrypted

# - "hostgssenc" is a TCP/IP socket that is GSSAPI-encrypted

# - "hostnogssenc" is a TCP/IP socket that is not GSSAPI-encrypted

#

# DATABASE can be "all", "sameuser", "samerole", "replication", a

# database name, or a comma-separated list thereof. The "all"

# keyword does not match "replication". Access to replication

# must be enabled in a separate record (see example below).

#
```

USER can be "all", a user name, a group name prefixed with "+", or a
comma-separated list thereof. In both the DATABASE and USER fields
you can also write a file name prefixed with "@" to include names
from a separate file.

#

ADDRESS specifies the set of hosts the record matches. It can be a
host name, or it is made up of an IP address and a CIDR mask that is
an integer (between 0 and 32 (IPv4) or 128 (IPv6) inclusive) that
specifies the number of significant bits in the mask. A host name
that starts with a dot (.) matches a suffix of the actual host name.

Alternatively, you can write an IP address and netmask in separate
columns to specify the set of hosts. Instead of a CIDR-address, you
can write "samehost" to match any of the server's own IP addresses,
or "samenet" to match any address in any subnet that the server is
directly connected to.

#

METHOD can be "trust", "reject", "md5", "password", "scram-sha-256",
"gss", "sspi", "ident", "peer", "pam", "ldap", "radius" or "cert".

Note that "password" sends passwords in clear text; "md5" or
"scram-sha-256" are preferred since they send encrypted passwords.

#

OPTIONS are a set of options for the authentication in the format

```
# NAME=VALUE. The available options depend on the different
# authentication methods -- refer to the "Client Authentication"
# section in the documentation for a list of which options are
# available for which authentication methods.
#
# Database and user names containing spaces, commas, quotes and other
# special characters must be quoted. Quoting one of the keywords
# "all", "sameuser", "samerole" or "replication" makes the name lose
# its special character, and just match a database or username with
# that name.
#
# This file is read on server startup and when the server receives a
# SIGHUP signal. If you edit the file on a running system, you have to
# SIGHUP the server for the changes to take effect, run "pg_ctl reload",
# or execute "SELECT pg_reload_conf()".
#
# Put your actual configuration here
# -----
#
# If you want to allow non-local connections, you need to add more
# "host" records. In that case you will also need to make PostgreSQL
```

```

# listen on a non-local interface via the listen_addresses

# configuration parameter, or via the -i or -h command line switches.


# DO NOT DISABLE!

# If you change this first entry you will need to make sure that the

# database superuser can access the database using some other method.

# Noninteractive access to all databases is required during automatic

# maintenance (custom daily cronjobs, replication, and similar tasks).

#

# Database administrative login by Unix domain socket

local  all            postgres                                peer

# TYPE  DATABASE        USER            ADDRESS                 METHOD

# "local" is for Unix domain socket connections only

local  all            all                                peer

# IPv4 local connections:

host   all            all             127.0.0.1/32            scram-sha-256

# IPv6 local connections:

host   all            all             ::1/128                  scram-sha-256

# Allow replication connections from localhost, by a user with the

# replication privilege.

local  replication    all                                peer

```

```
host replication all 127.0.0.1/32 scram-sha-256

host replication all ::1/128 scram-sha-256

host protection_donnees webuser 127.0.0.1/32 scram-sha-256
```

Pour sécuriser les mots de passes de la base de donnée, j'ai utilisé **password_hash()** pour hacher le mot de passe de l'utilisateur avant de le stocker dans la base de données, dans **register.php**. J'ai également utilisé **password_verify()** pour vérifier si le mot de passe soumis par l'utilisateur correspond au mot de passe haché stocké dans la base de donnée, dans **login.php**.

Configuration de Apache

On a modifié ces fichiers d'apache (les configs sont à la sécurisation du site):

```
sudo nano /etc/apache2/sites-available/protection-donnees.conf
```

```
sudo nano /etc/apache2/sites-available/000-default.conf
```

```
sudo nano /etc/apache2/apache2.conf
```

```
sudo nano /etc/apache2/conf-available/security.conf
```

On active dans le fichier: **/etc/apache2/conf-available/security.conf**

```
ServerTokens Prod
```

```
ServerSignature Off
```

On modifie les fichiers php sécurisés dans /var/www/html:

```
config.php
```

```
<?php
```

```
session_start([
```

```
    'cookie_httponly' => true, // Protection contre le vol de session via JavaScript
```

```
    'cookie_secure' => isset($_SERVER['HTTPS']), // Utilisation du HTTPS
```

```
    'cookie_samesite' => 'Strict' // Protection CSRF
```

```

]);

$host = "localhost";

$dbname = "protection_donnees";

$user = "webuser";

$password = "progr00"; // À changer en prod

try {

    $pdo = new PDO("pgsql:host=$host;dbname=$dbname", $user, $password, [

        PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,

        PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,

        PDO::ATTR_EMULATE_PREPARES => false // Sécurité contre les injections SQL

    ]);

} catch (PDOException $e) {

    die("Erreur de connexion à la base de données.");

}

?>

```

home.php

```
<?php
```

```
require 'config.php';
```

```
if (!isset($_SESSION['user'])) {
```

```
    header("Location: login.php");
```

```
    exit();
```

```
}

?>

<!DOCTYPE html>

<html lang="fr">

<head>

    <meta charset="UTF-8">

    <title>Accueil</title>

</head>

<body>

    <h2>Bienvenue, <?php echo htmlspecialchars($_SESSION['user'], ENT_QUOTES,
'UTF-8'); ?> !</h2>

    <p>Ceci est la page après connexion.</p>

    <a href="logout.php">Se déconnecter</a>

</body>

</html>
```

index.php

```
<?php

session_start();

if (!isset($_SESSION["user"])) {

    header("Location: login.php");

    exit();
```

```
}

?>

<!DOCTYPE html>

<html lang="fr">

<head>

    <meta charset="UTF-8">

    <title>Accueil</title>

</head>

<body>

    <h2>Bienvenue sur le site</h2>

    <a href="register.php">Inscription</a> |

    <a href="login.php">Connexion</a>

</body>

</html>
```

login.php

```
<?php

require 'config.php';

session_start();

if ($_SERVER["REQUEST_METHOD"] == "POST") {

    // Vérification du CSRF

    if (!isset($_POST['csrf_token']) || $_POST['csrf_token'] !== $_SESSION['csrf_token']) {
```

```

        die("Erreur CSRF !");
    }

    // Vérification du CAPTCHA

    if (!isset($_POST['captcha']) || $_POST['captcha'] !== $_SESSION['captcha']) {

        die("CAPTCHA invalide, merci de réessayer.");

    }

    // Récupérer les informations de l'utilisateur

    $username = trim($_POST['username']);

    $password = $_POST['password'];

    // Vérifier si l'utilisateur existe dans la base de données

    $stmt = $pdo->prepare("SELECT * FROM users WHERE username = :username");

    $stmt->execute(['username' => $username]);

    $user = $stmt->fetch();

    if ($user && password_verify($password, $user['password'])) {

        // Si l'utilisateur est trouvé, démarrer la session et rediriger vers la page d'accueil

        $_SESSION['user'] = $user['username'];

        header("Location: home.php");

        exit();

    } else {

        echo "Nom d'utilisateur ou mot de passe incorrect.";

    }

}

```

```
// Générer un nouveau token CSRF pour chaque requête
```

```
$_SESSION['csrf_token'] = bin2hex(random_bytes(32));
```

```
?>
```

```
<!DOCTYPE html>
```

```
<html lang="fr">
```

```
<head>
```

```
    <meta charset="UTF-8">
```

```
    <title>Connexion</title>
```

```
    <link rel="stylesheet" href="style.css">
```

```
</head>
```

```
<body>
```

```
    <h2>Connexion</h2>
```

```
    <form method="post">
```

```
        <!-- CSRF Token pour la sécurité -->
```

```
        <input type="hidden" name="csrf_token" value="<?= $_SESSION['csrf_token']; ?>">
```

```
        <!-- Champs de connexion -->
```

```
        <input type="text" name="username" placeholder="Nom d'utilisateur" required>
```

```
        <input type="password" name="password" placeholder="Mot de passe" required>
```

```
        <!-- CAPTCHA -->
```

```
        <p><strong>Entrez le CAPTCHA :</strong></p>
```

```
        <p></p>
```

```
<input type="text" name="captcha" placeholder="Entrez le code" required>

<!-- Bouton de soumission -->

<button type="submit">Se connecter</button>

</form>

<!-- Lien vers la page d'inscription si l'utilisateur n'a pas de compte -->

<a href="register.php">Pas encore de compte ? Inscrivez-vous</a>

</body>

</html>
```

logout.php

```
<?php

session_start();

session_unset();

session_destroy();

header("Location: login.php");

exit();

?>
```

register.php

```
<?php

require 'config.php';

session_start();

$error = ""; // Variable pour stocker les messages d'erreur
```

```
if ($_SERVER["REQUEST_METHOD"] == "POST") {  
  
    // Vérification du CSRF  
  
    if (!isset($_POST['csrf_token']) || $_POST['csrf_token'] !== $_SESSION['csrf_token']) {  
  
        $error = "Erreur CSRF !";  
  
    }  
  
    // Récupération des données du formulaire  
  
    $username = htmlspecialchars(trim($_POST['username']), ENT_QUOTES, 'UTF-8');  
  
    $password = $_POST['password'];  
  
    // Vérification de la robustesse du mot de passe  
  
    if (strlen($password) < 12) {  
  
        $error = "Le mot de passe doit contenir au moins 12 caractères.";  
  
    }  
  
    elseif (!preg_match('/[A-Z]/', $password)) {  
  
        $error = "Le mot de passe doit contenir au moins une majuscule.";  
  
    }  
  
    elseif (!preg_match('/[a-z]/', $password)) {  
  
        $error = "Le mot de passe doit contenir au moins une minuscule.";  
  
    }  
  
    elseif (!preg_match('/[0-9]/', $password)) {  
  
        $error = "Le mot de passe doit contenir au moins un chiffre.";  
  
    }  
  
}
```

```

elseif (!preg_match('/[W_]/', $password)) {

    $error = "Le mot de passe doit contenir au moins un caractère spécial (ex : @, #, $, etc.).";

}

elseif (preg_match('/123456|password|qwerty|abc123/i', $password)) {

    $error = "Le mot de passe ne doit pas être trop simple (évitez des mots comme '123456'
ou 'password').";

}

// Si aucune erreur, on enregistre l'utilisateur

if (!$error) {

    if (!empty($username) && !empty($password)) {

        $hashedPassword = password_hash($password, PASSWORD_BCRYPT);

        // Insertion de l'utilisateur dans la base de données

        $stmt = $pdo->prepare("INSERT INTO users (username, password) VALUES
(:username, :password)");

        try {

            $stmt->execute(['username' => $username, 'password' => $hashedPassword]);

            header("Location: login.php");

            exit();

        } catch (PDOException $e) {

            $error = "Erreur : " . htmlspecialchars($e->getMessage(), ENT_QUOTES, 'UTF-8');

        }

    } else {

        $error = "Veuillez remplir tous les champs.";
    }
}

```

```

    }

}

}

// Générer un nouveau token CSRF pour chaque requête
$_SESSION['csrf_token'] = bin2hex(random_bytes(32));

?>

<!DOCTYPE html>

<html lang="fr">

<head>

    <meta charset="UTF-8">

    <title>Inscription</title>

    <link rel="stylesheet" href="style.css">

</head>

<body>

    <h2>Inscription</h2>

    <?php if ($error): ?>

        <div style="color: red;"><?= $error; ?></div>

    <?php endif; ?>

    <form method="post">

        <!-- CSRF Token pour la sécurité -->

```

```
<input type="hidden" name="csrf_token" value="<?= $_SESSION['csrf_token']; ?>">

<!-- Champs d'inscription -->

<input type="text" name="username" placeholder="Nom d'utilisateur" required>

<!-- Affichage des règles pour le mot de passe -->

<p><strong>Le mot de passe doit contenir :</strong></p>

<ul>

    <li>Au moins 12 caractères</li>

    <li>Une majuscule</li>

    <li>Une minuscule</li>

    <li>Un chiffre</li>

    <li>Un caractère spécial (ex : @, #, $, etc.)</li>

    <li>Il ne doit pas contenir de séquences simples (ex : '123456', 'password')</li>

</ul>

<input type="password" name="password" placeholder="Mot de passe" required>

<!-- CAPTCHA -->

<p><strong>Entrez le CAPTCHA :</strong></p>

<p></p>

<input type="text" name="captcha" placeholder="Entrez le CAPTCHA" required>

<!-- Bouton de soumission -->

<button type="submit">S'inscrire</button>

</form>
```

```
<!-- Lien vers la page de connexion si l'utilisateur a déjà un compte -->
```

```
<a href="login.php">Déjà inscrit ? Connectez-vous</a>
```

```
</body>
```

```
</html>
```

captcha.php

```
<?php
```

```
session_start();
```

```
// Créer une image
```

```
$image = imagecreatetruecolor(120, 40);
```

```
// Définir des couleurs
```

```
$bg_color = imagecolorallocate($image, 255, 255, 255); // Fond blanc
```

```
$text_color = imagecolorallocate($image, 0, 0, 0); // Texte noir
```

```
// Remplir l'image avec la couleur de fond
```

```
imagefill($image, 0, 0, $bg_color);
```

```
// Générer un code CAPTCHA aléatoire
```

```
$captcha_code = rand(1000, 9999);
```

```
$_SESSION['captcha'] = (string)$captcha_code; // Enregistrer le code CAPTCHA dans la session
```

```
// Ajouter du texte (Captcha) sur l'image
```

```
$font = '/usr/share/fonts/truetype/msttcorefonts/arial.ttf'; // Chemin vers la police
```

```
imagettftext($image, 20, 0, 30, 30, $text_color, $font, $captcha_code);
```

```
// Définir les entêtes pour afficher l'image
```

```
header("Content-Type: image/png");
```

```
imagepng($image);
```

```
// Libérer la mémoire
```

```
imagedestroy($image);
```

```
?>
```

Sécurisation du site

Mise en place d'un captcha

On installe la police Arial

```
sudo apt install ttf-mscorefonts-installer -y
```

Générer un certificat SSL

```
sudo apt update && sudo apt install apache2 openssl
```

```
sudo systemctl restart apache2
```

```
openssl req -new -x509 -keyout /etc/ssl/private/lisa.com.key -out /etc/ssl/certs/lisa.com.crt -days 365
```

Configuration SSL Apache

On modifie /etc/apache2/sites-available/default-ssl.conf:

```
<IfModule mod_ssl.c>
```

```
    <VirtualHost _default_:443>
```

```
        ServerAdmin webmaster@localhost
```

```
        ServerName 192.31.25.14
```

DocumentRoot /var/www/html

Logs

ErrorLog \${APACHE_LOG_DIR}/error.log

CustomLog \${APACHE_LOG_DIR}/access.log combined

Activation SSL

SSLEngine on

SSLCertificateFile /etc/ssl/certs/lisa.com.crt

SSLCertificateKeyFile /etc/ssl/private/lisa.com.key

Forcer l'utilisation des protocoles sécurisés

SSLProtocol all -SSLv3 -TLSv1 -TLSv1.1

SSLCipherSuite HIGH:!aNULL:!MD5:!3DES

SSLHonorCipherOrder on

SSLCompression off

SSLSessionTickets off

Sécurité des en-têtes HTTP

<IfModule mod_headers.c>

Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains; preload"

Header always set X-Frame-Options "DENY"

Header always set X-Content-Type-Options "nosniff"

Header always set Referrer-Policy "no-referrer-when-downgrade"

Header always set Content-Security-Policy "default-src 'self'; script-src 'self'; object-src 'none';"

Header always set X-XSS-Protection "1; mode=block"

Header always set Permissions-Policy "geolocation=(self), microphone=(), camera=()"

</VirtualHost>

</IfModule>

Ensuite /etc/apache2/sites-available/000-default.conf:

#securisation http

<IfModule mod_headers.c>

Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains; preload"

Header always set X-Frame-Options "DENY"

Header always set X-Content-Type-Options "nosniff"

Header always set Referrer-Policy "no-referrer-when-downgrade"

Header always set Content-Security-Policy "default-src 'self'; script-src 'self'; object-src 'none';"

Header always set X-XSS-Protection "1; mode=block"

Header always set Permissions-Policy "geolocation=(self), microphone=(), camera=()"

</IfModule>

Ne pas oublier:

sudo a2enmod headers

sudo systemctl restart apache2

Explication des en-têtes utilisées: **Content-Security-Policy (CSP)**: Protège contre les attaques XSS en limitant les sources autorisées pour les scripts, images, styles, etc.

X-Frame-Options : Empêche l'affichage du site dans un iframe pour éviter les attaques de clickjacking.

Strict-Transport-Security (HSTS): Force l'utilisation du HTTPS en empêchant les connexions HTTP sur ton site.

X-Content-Type-Options: Empêche le navigateur de deviner le type de fichier (MIME sniffing), évitant ainsi certains types d'attaques.

Referrer-Policy: Contrôle quelles informations de l'URL source sont envoyées aux autres sites lorsqu'un utilisateur clique sur un lien.

Permissions-Policy: Restreint l'accès à certaines API et fonctionnalités du navigateur (caméra, micro, géolocalisation...).

X-XSS-Protection: Active la protection contre les attaques XSS dans certains navigateurs (comme Internet Explorer et Chrome), en bloquant les pages suspectes.

Configurer la redirection HTTP vers HTTPS

On modifie /etc/apache2/sites-available/000-default.conf:

```
<VirtualHost *:80>
```

```
    ServerName lisa.com
```

```
    ServerAdmin webmaster@localhost
```

```
    DocumentRoot /var/www/html
```

```
    # Redirection HTTP -> HTTPS
```

```
    Redirect permanent / https://lisa.com/
```

```
    ErrorLog ${APACHE_LOG_DIR}/error.log
```

```
    CustomLog ${APACHE_LOG_DIR}/access.log combined
```

```
</VirtualHost>
```

On modifie /etc/hosts pour mon nom de domaine:

192.31.25.14 lisa.com

Pour vérifier que le certificat SSL fonctionne:

```
curl -I -k https://lisa.com
```

Vérification

SQL

```
sudo -u postgres psql
```

```
\c protection_donnees
```

```
SELECT * FROM users;
```

→F12

→Network

→Refresh F5

→Requête principale

→onglet Headers

en-têtes:

```
curl -I http://192.31.25.14
```

```
nikto -h http://192.31.25.14
```

Test de sécurité (Hault Théo)

Rapport d'Analyse des Attaques et Mesures de Sécurité

1. Attaque : ARP Spoofing avec Sniffing Réseau

Méthode Utilisée

L'attaque a été réalisée en utilisant **Bettercap**, un outil puissant permettant l'usurpation d'adresse ARP et l'interception du trafic réseau.

1. Activation de la surveillance réseau avec `net.probe`.
2. Identification des hôtes actifs dans le sous-réseau.
3. Ciblage d'un hôte spécifique avec `set arp.spoof.targets 192.168.1.3`.
4. Activation du spoofing ARP avec `arp.spoof on`.
5. Capture du trafic réseau avec `net.sniff on`.

Exploitation et Impact

- L'attaque permet de rediriger le trafic entre la cible et la passerelle, permettant ainsi l'interception des requêtes HTTP.
- Capture de plusieurs requêtes GET à destination de `172.16.1.2`, révélant des ressources demandées par la cible.

Mesures de Sécurité

- **Activation du filtrage ARP dynamique** : empêche les mises à jour non autorisées de la table ARP.
- **Utilisation du protocole ARP sécurisé (DAI)** : détecte et bloque les attaques ARP spoofing.
- **Utilisation du chiffrement réseau (HTTPS, VPN)** : réduit l'impact de l'interception des données.

└─# bettercap

bettercap v2.33.0 (built for linux amd64 with go1.22.6) [type 'help' for a list of commands]

192.168.1.0/24 > 192.168.1.4 » [05:59:28] [sys.log] [inf] gateway monitor started ...

192.168.1.0/24 > 192.168.1.4 » net.probe on

[05:59:34] [sys.log] [inf] net.probe starting net.recon as a requirement for net.probe\

192.168.1.0/24 > 192.168.1.4 » [05:59:34] [sys.log] [inf] net.probe probing 256 addresses on 192.168.1.0/24\

192.168.1.0/24 > 192.168.1.4 » [05:59:34] [endpoint.new] endpoint 192.168.1.3 detected as 08:00:27:00:01:43 (PCS Systemtechnik GmbH).

192.168.1.0/24 > 192.168.1.4 » set arp.spoof.targets 192.168.1.3

192.168.1.0/24 > 192.168.1.4 » arp.spoof on

[06:00:32] [sys.log] [inf] arp.spoof enabling forwarding

192.168.1.0/24 > 192.168.1.4 » [06:00:32] [sys.log] [inf] arp.spoof arp spoofer st

192.168.1.0/24 > 192.168.1.4 » net.sniff on

192.168.1.0/24 > 192.168.1.4 » [06:08:11] [net.sniff.http.request] http 192.168.1.3 GET 172.16.1.2/

192.168.1.0/24 > 192.168.1.4 » [06:08:11] [net.sniff.http.request] http 192.168.1.3 GET 172.16.1.2/

192.168.1.0/24 > 192.168.1.4 » [06:08:12] [net.sniff.http.request] http 192.168.1.3 GET 172.16.1.2/icons/ubuntu-logo.png

192.168.1.0/24 > 192.168.1.4 » [06:08:12] [net.sniff.http.request] http 192.168.1.3 GET 172.16.1.2/favicon.ico

192.168.1.0/24 > 192.168.1.4 » [06:08:12] [net.sniff.http.request] http 192.168.1.3 GET 172.16.1.2/icons/ubuntu-logo.png

192.168.1.0/24 > 192.168.1.4 » [06:08:12] [net.sniff.http.request] http 192.168.1.3 GET 172.16.1.2/favicon.ico

192.168.1.0/24 > 192.168.1.4 »

2. Attaque : Prise de Contrôle du Root STP

Méthode Utilisée

L'attaque a été menée via l'outil **Yersinia**, qui permet d'exploiter les failles du protocole Spanning Tree Protocol (STP).

1. Exécution de `yersinia stp -attack 4` pour envoyer des paquets revendiquant le rôle de Root Bridge.
2. Le switch ESW1 a accepté la requête, définissant l'attaquant comme le Root Bridge.

Exploitation et Impact

- L'attaquant prend le contrôle du réseau en forçant le trafic à passer par sa machine.
- Possibilité d'exécuter des attaques de type Man-in-the-Middle (MITM) et de perturber le réseau.

Mesures de Sécurité

- **Activation de BPDU Guard** : empêche l'introduction de nouveaux Root Bridges non autorisés.
- **Utilisation de Root Guard** : protège les ports contre les revendications root frauduleuses.
- **Segmentation VLAN** : réduit la portée des attaques STP.

```
└─(root@kali)-[/home/kali]
```

```
└─# yersinia stp -attack 4
```

Warning: interface eth0 selected as the default one

<*> Starting NONDOS attack Claiming Root Role...

<*> Press any key to stop the attack <*>

ESW1#show spanning-tree root

VLAN1

Root ID Priority 32768

Address cc04.01f4.0000

Cost 19

Port 41 (FastEthernet1/0) (notre kali)

Hello Time 2 sec Max Age 20 sec Forward Delay 15 sec

3. Attaque : DoS DHCP Request

Méthode Utilisée

L'attaque a été réalisée avec **Yersinia**, en envoyant un grand nombre de requêtes DHCP DISCOVER.

1. Exécution de `yersinia dhcp -attack 1`.
2. Envoi massif de requêtes DISCOVER pour saturer le serveur DHCP.

Exploitation et Impact

- Saturation du pool d'adresses DHCP, empêchant les nouveaux clients d'obtenir une adresse IP.
- Perturbation du réseau en rendant impossible la connexion de nouveaux appareils.

Mesures de Sécurité

- **Activation de DHCP Snooping** : filtre les requêtes DHCP non autorisées.
- **Limitation du nombre de requêtes DHCP par port** : prévient les attaques DoS.
- **Attribution d'adresses IP statiques aux équipements critiques.**

```
yersinia dhcp -attack 1
```

```
Warning: interface eth0 selected as the default one
```

```
<*> Starting DOS attack sending DISCOVER packet...
```

```
<*> Press any key to stop the attack <*>
```

4. Attaque : DNS Spoofing

Méthode Utilisée

Cette attaque a été effectuée en utilisant **Bettercap** et un serveur HTTP local.

1. Lancement d'un serveur HTTP avec `python3 -m http.server --bind 192.168.1.2 80`.
2. Activation du spoofing DNS avec `dns.spoof on` et définition du domaine cible.
3. Envoi de réponses DNS falsifiées, redirigeant les requêtes vers l'attaquant.

Exploitation et Impact

- Détournement des utilisateurs vers des sites malveillants.
- Possibilité de vol d'identifiants et d'informations sensibles.

Mesures de Sécurité

- **Utilisation de DNSSEC** : authentifie les réponses DNS.
- **Configuration de serveurs DNS fiables** : empêche l'utilisation de serveurs DNS compromis.
- **Filtrage des réponses DNS suspectes** via un pare-feu.

└─# bettercap

bettercap v2.33.0 (built for linux amd64 with go1.22.6) [type 'help' for a list of commands]

192.168.1.0/24 > 192.168.1.4 » [06:24:22] [sys.log] [inf] gateway monitor started ...

192.168.1.0/24 > 192.168.1.4 » net.probe on

[06:24:33] [sys.log] [inf] net.probe starting net.recon as a requirement for net.probe

192.168.1.0/24 > 192.168.1.4 » [06:24:33] [sys.log] [inf] net.probe probing 256 addresses on 192.168.1.0/24

192.168.1.0/24 > 192.168.1.4 » [06:24:33] [endpoint.new] endpoint 192.168.1.3 detected as 08:00:27:00:01:43 (PCS Systemtechnik GmbH).

192.168.1.0/24 > 192.168.1.4 » set arp.spoof.targets 192.168.1.3

192.168.1.0/24 > 192.168.1.4 » arp.spoof on

192.168.1.0/24 > 192.168.1.4 » [06:25:11] [sys.log] [inf] arp.spoof arp spoofer started, probing 1 targets.

192.168.1.0/24 > 192.168.1.4 » set dns.spoof.domains moniut-rt

192.168.1.0/24 > 192.168.1.4 » dns.spoof on

192.168.1.0/24 > 192.168.1.4 » [06:26:09] [sys.log] [inf] dns.spoof moniut-rt -> 192.168.1.4

192.168.1.0/24 > 192.168.1.4 » [06:26:35] [sys.log] [inf] dns.spoof sending spoofed DNS reply for moniut-rt (->192.168.1.4) to 192.168.1.3 : 08:00:27:00:01:43 (PCS Systemtechnik GmbH).

192.168.1.0/24 > 192.168.1.4 » [06:26:35] [sys.log] [inf] dns.spoof sending spoofed DNS reply for moniut-rt (->192.168.1.4) to 192.168.1.3 : 08:00:27:00:01:43 (PCS Systemtechnik GmbH).

192.168.1.0/24 > 192.168.1.4 » [06:27:02] [sys.log] [inf] dns.spoof sending spoofed DNS reply for moniut-rt (->192.168.1.4) to 192.168.1.3 : 08:00:27:00:01:43 (PCS Systemtechnik GmbH).

192.168.1.0/24 > 192.168.1.4 » [06:27:02] [sys.log] [inf] dns.spoof sending spoofed DNS reply for moniut-rt (->192.168.1.4) to 192.168.1.3 : 08:00:27:00:01:43 (PCS Systemtechnik GmbH).

192.168.1.0/24 > 192.168.1.4 » [06:27:24] [sys.log] [inf] dns.spoof sending spoofed DNS reply for moniut-rt (->192.168.1.4) to 192.168.1.3 : 08:00:27:00:01:43 (PCS Systemtechnik GmbH).

192.168.1.0/24 > 192.168.1.4 » [06:27:24] [sys.log] [inf] dns.spoof sending spoofed DNS reply for moniut-rt (->192.168.1.4) to 192.168.1.3 : 08:00:27:00:01:43 (PCS Systemtechnik GmbH).

192.168.1.0/24 > 192.168.1.4 »

Recommandations du Guide ANSSI (Julien Picamal)

Liste des Recommandations

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
R1	Modifier les éléments de configuration par défaut	Oui	Retenue	Totalement mis en œuvre	Nous avons modifier les configuration de base	
R1-	Pallier l'impossibilité de changer un élément par défaut	Non	n.a.	n.a.		tous les système on pu etre modifier
R2	Installer uniquement les services ou fonctionnalités indispensables	Oui	Retenue	Totalement mis en œuvre	Seul les système nesseraire on été installer	
R2-	Pallier l'impossibilité de	Oui	Exclue	n.a.		Seul les système nesseraire

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
	désinstaller un service non indispensable					on été installer
R3	Définir et utiliser des configurations de référence	Non	Retenue	Totalement mis en œuvre	Des configurations de référence sans superflus ont été comme base	
R4	Établir un inventaire technique des éléments et des accès au SIE	Non	Retenue	Pas commencé		
R5	Utiliser uniquement des équipements maîtrisés	Oui	Retenue	Partiellement mis en œuvre	nous avons utiliser majoritairement des materiel connu mais certain tel	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
					que les firewall	
R6	Dédier aux SIE des supports amovibles identifiés	Oui	n.a.	n.a.		pas de materiel physique
R7	Décontaminer les supports amovibles avant leur utilisation	Oui	n.a.	n.a.		pas de materiel physique
R7+	Utiliser un équipement dédié à l'analyse des supports amovibles	Non	n.a.	n.a.		pas de materiel physique
R8	Mettre en œuvre une traçabilité de l'utilisation des supports amovibles	Non	n.a.	n.a.		pas de materiel physique

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
R8+	Mettre en œuvre un outil de protection contre l'exfiltration de données	Non	Exclue	n.a.		pas dans le domaine de la SAE
R9	Segmenter le SI en systèmes et sous-systèmes	Oui	Retenue	Totalement mis en œuvre	Les systèmes d'administration, de production et serveur web sont séparée grace a des règles de firewall et ACL.	
R10	Autoriser les interconnexions suivant le besoin de fonctionnement	Oui	Retenue	Totalement mis en œuvre	Seuls les systèmes légitimes à accéder à un système y ont accès.	
R11	Mettre en place un cloisonnement	Oui	Retenue	Totalement mis en œuvre	Le nombre d'interconnexion a été	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
	ment physique				réduit au minimum.	
R11-	Mettre en place un cloisonnement logique par le chiffre	Oui	Exclue	n.a.		Pas nécessaire .
R11- -	Mettre en place un cloisonnement logique	Oui	Retenue	Totalement mis en œuvre	Les systèmes qui ne doivent pas communiquer sont cloisonnés grâce à des acl et des règles pare-feu.	
R12	Chiffrer les données en amont du stockage avec des secrets distincts	Non	Retenue	Pas commencé		

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
R13	Contrôler le cloisonnement mis en place en cas d'externalisation	Oui	n.a.	n.a.		pas d'externalisation
R14	Infrastructures numériques : cloisonner les services internes	Oui	Retenue	Partiellement mis en œuvre	Le réseau d'administration a accès direct au serveur web et internet mais les réseaux prod et service sont cloisonner	
R15	Segmenter les SIE publics en au moins deux sous-systèmes	Oui	Retenue	Totalement mis en œuvre	Utilisation d'une dmz pour les serveur web publique	
R16	Accès public : chiffrer et	Oui	Retenue	Totalement mis en œuvre	Le serveur Web utilise le	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
	authentifier les flux au niveau applicatif				protocole HTTPS	
R17	Accès public : authentifier les utilisateurs	Non	Retenue	Totalement mis en œuvre	Le serveur Web authentifie les utilisateur qui se connecte avec un login et mots de passe	
R17+	Accès public : authentifier les utilisateurs avec deux facteurs	Non	Retenue	Pas commencé		Aucun 2FA n'a été mis en place
R18	Accès nomade : mettre en place un tunnel chiffré et authentifié	Oui	Exclue	n.a.		Pas de d'utilisateur nomade.

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
R19	Accès nomade : authentifier les utilisateurs avec deux facteurs	Oui	Exclue	n.a.		Pas de d'utilisateur nomade.
R20	Accès nomade : chiffrer intégralement le disque du poste	Oui	Exclue	n.a.		Pas de d'utilisateur nomade.
R21	Accès nomade : utiliser des filtres de confidentialité	Non	Exclue	n.a.		Pas de d'utilisateur nomade.
R22	Accès interne : mettre en place un tunnel chiffré et authentifié	Oui	Retenue	Totalement mis en œuvre	Creation d'un tunnel IPSEC entre les deux site	
R23	Filtrer les flux aux interconne	Oui	Retenue	Totalement mis en œuvre	Les flux sont filtrer grace au	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
	xions entre les systèmes et entre les sous-systèmes				ACL et aux règles du firewall	
R23+	Filtrer les flux aux extrémités des communications	Non	Exclue	n.a.		Aucun filtrage aux extrémités n'a été mis en place.
R24	Définir les besoins de filtrage sur le SIE	Oui	Retenue	Totalement mis en œuvre	Definie dans le cahier des charges	
R25	Formaliser les règles de filtrage	Oui	Exclue	n.a.		Manque de temps
R26	Passer régulièrement en revue les règles de filtrage	Non	Exclue	n.a.		Pas dans le domaine de la SAE
R27	Mettre en œuvre le filtrage grâce à	Non	Retenue	Totalement mis en œuvre	Utilisation de Firewall dedier	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
	des équipements spécialisés					
R28	Bloquer tous les flux non explicitement autorisés	Oui	Retenue	Totalement mis en œuvre	On a utilisé des ACL pour bloquer les flux non autorisés	
R29	Utiliser des comptes d'administration dédiés	Oui	Retenue	Totalement mis en œuvre	Les comptes utilisateur et administrateurs sont distincts.	
R29-	Pallier l'absence de comptes dédiés à l'administration	Oui	Exclue	n.a.		Il existe des comptes administrateurs.
R30	Utiliser par défaut des comptes d'administration individuels	Oui	Retenue	Totalement mis en œuvre	Chaque administrateur possède son propre	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
					compte admin	
R31	Attribuer les droits d'administration à des groupes	Non	Retenue	Pas commencé		pas de service LDAP
R32	Protéger l'accès aux annuaires des comptes d'administration	Non	Exclue	n.a.		pas de service LDAP
R33	Renforcer l'authentification pour les comptes d'administration	Non	Retenue	Totalement mis en œuvre	Les mots de passe répondent à restriction de caractère minimum et sont hachés avant d'être stockés.	
R34	Empêcher le stockage	Oui	Retenue	Totalement mis en œuvre	Les secrets ne sont pas	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
	des secrets d'authentification dans les journaux				stocker dans les journaux	
R35	Respecter le principe du moindre privilège dans l'attribution des droits d'administration	Oui	Retenue	Totalement mis en œuvre	Chaque compte utilisateur est spécialisé dans un seul système.	
R36	N'utiliser que des équipements maîtrisés pour l'administration	Oui	Retenue	Totalement mis en œuvre	Les équipements utilisés pour l'administration sont contrôlés par l'administration	
R37	Utiliser un poste d'administration dédié	Oui	Retenue	Totalement mis en œuvre	Un poste est dédié à l'administration.	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
R37-	Accéder aux autres environnements de travail depuis le poste d'administration	Oui	Retenue	Totalement mis en œuvre	Le poste d'administration est capable d'autre tâche.	
R38	Renforcer la sécurité du poste d'administration	Oui	Retenue	Totalement mis en œuvre	Le poste d'administration ne possède la possibilité d'accéder à internet ou seulement à certain site spécifique	
R39	Connecter les ressources d'administration sur un réseau physique dédié	Oui	Retenue	Totalement mis en œuvre	La ressource d'administration est sur un réseau dédié.	
R39-	Connecter les	Oui	Exclue	n.a.		

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
	ressources d'administration sur un réseau VPN IPsec dédié					
R39- -	Pallier l'absence de chiffrement des flux d'administration	Oui	Retenue	Pas commencé		Les flux ne sont pas chiffrés, ils sont uniquement
R40	Dédier une interface réseau physique d'administration	Non	Exclue	n.a.		Le système ne possède pas de port d'administration.
R40-	Dédier une interface réseau virtuelle d'administration	Non	Exclue	n.a.		Le système ne possède pas de port d'administration virtuel.

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
R41	Cloisonner et filtrer le réseau d'administration	Non	Retenue	Partiellement mis en œuvre	Les réseaux sont cloisonnés grâce aux ACL et au firewall qui limite les flux non autorisés.	
R42	Utiliser des protocoles sécurisés pour l'administration	Non	Retenue	Totalement mis en œuvre	Pour administrer les systèmes le protocole SSH est utilisée	
R43	Administrer des SI différents avec des serveurs outils différents	Non	Retenue	Totalement mis en œuvre	Chaque site possède des administrations séparées capables d'administrer l'autre site.	
R44	Utiliser des comptes individuels	Oui	Retenue	Totalement mis en œuvre	Chaque utilisateur	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
					possede son propre compte	
R44-	Pallier l'absence de comptes individuels	Oui	n.a.	n.a.		Chaque utilisateur possède son propre compte
R45	Désactiver les comptes inutilisés	Oui	Retenue	Totalement mis en œuvre	les compte inutilisée ont été supprimé	
R46	Mettre en œuvre un mécanisme d'authentification pour chaque compte	Oui	Retenue	Totalement mis en œuvre	La connexion necessite la verification grace a un capcha visuel	
R47	Établir une politique de gestion des secrets d'authentification	Oui	Retenue	Totalement mis en œuvre	Les mots de passe ont un nombre le caractère minimum ainsi que de	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
					caractères spéciaux.	
R48	Interdire le partage de secrets d'authentification	Oui	Retenue	Totalement mis en œuvre	Les mots de passe sont systématiquement chiffrés ou hacher.	
R48-	Protéger les secrets d'authentification des comptes partagés	Oui	Retenue	Totalement mis en œuvre	Le secret associé à un compte partagé doit être re-nouvelé chaque fois qu'un utilisateur le perd	
R49	Dédier un mot de passe à chaque compte privilégié	Oui	Retenue	Totalement mis en œuvre	Chaque compte administrateur possède un mot de passe complexe unique	
R50	Stocker les mots de	Non	Exclue	n.a.		Non applicable

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
	passer dans un coffre-fort de mots de passe					
R51	Renouveler régulièrement les secrets d'authentification	Oui	Retenue	Totalement mis en œuvre	Les mots de passe d'administration sont mis à jour tous les 6 mois et 12 pour les utilisateurs	
R51-	Pallier l'impossibilité de modifier un secret d'authentification	Oui	Exclue	n.a.		Il est toujours possible de changer les mots de passe
R52	Contrôler le renouvellement et l'accès aux secrets d'authentification	Oui	Retenue	Totalement mis en œuvre	Seul l'administrateur peut changer les mots de passe	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
R53	Renouveler immédiatement des secrets d'authentification	Non	Retenue	Totalement mis en œuvre	Les secrets sont mis à jour d'est que nécessaire .	pas dans le domaine de la SAE
R54	Définir une politique de gestion des droits d'accès	Oui	Exclue	n.a.		
R55	Attribuer les droits d'accès suivant le principe du moindre privilège	Oui	Retenue	Totalement mis en œuvre	Chaque utilisateur obtient des privilèges que lorsque cela est absolument nécessaire .	
R56	Définir une traçabilité des comptes privilégiés	Oui	n.a.	n.a.		Pas dans le domaine de la SAE

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
R57	Faire une revue régulière des droits d'accès	Oui	n.a.	n.a.		Pas dans le domaine de la SAE
R58	Documenter une politique de MCS	Oui	n.a.	n.a.		Pas dans le domaine de la SAE
R59	Mettre en place une veille de sécurité	Oui	n.a.	n.a.		Pas dans le domaine de la SAE
R60	Obtenir des mises à jour de sécurité officielles	Non	Retenue	Totalement mis en œuvre	Les mise à jour provienne des site ou repo officiel	
R61	Appliquer les mises à jour de sécurité	Oui	Retenue	Totalement mis en œuvre	Les mise à jour ont été effectuées	
R62	Utiliser des logiciels et des matériels supportés	Oui	Retenue	Partiellement mis en œuvre	Les logiciel et le matériels sont majoritairement des	

Identifiant	Intitulé de la recommandation	Associée à une exigence d'une règle	Mesure retenue, exclue ou non applicable ?	Niveau de mise en œuvre	Plan d'action / Commentaires	Justification en cas d'exclusion ou de non applicabilité de la mesure
					système supportés mais certain le sont pas	
R62-	Pallier l'utilisation de versions obsolètes de logiciels et de matériels	Oui	Exclue	n.a.		

Statut des Recommandations ANSSI

Statut	Recommandations ANSSI
Totalement mis en œuvre	40
Partiellement mis en œuvre	4
Pas commencé	5
Problème !	0
n.a.	30